

Vorlesung Cybersicherheit, Sommersemester 2025

Kryptowährungen: Bitcoin

Prof. Dr.-Ing. Lucas Vincenzo Davi

Fakultät für Informatik

Arbeitsgruppe Systemsicherheit <https://www.syssec.wiwi.uni-due.de/>

Universität Duisburg-Essen

© SYSSEC, Prof. Dr. Lucas Davi

- Rückblick
 - Digitale Signaturen
 - Hash Funktionen
 - Man-In-The-Middle (MITM) Angriff
 - Zertifikate
- Themen heute
 - Bitcoin
 - Digitales Geld
 - Merkle Bäume
 - Distributed Consensus
 - Incentives Engineering



Kryptografie

- Symmetrische Kryptografie
- Asymmetrische Kryptografie
- Hash Funktionen und Digitale Signaturen

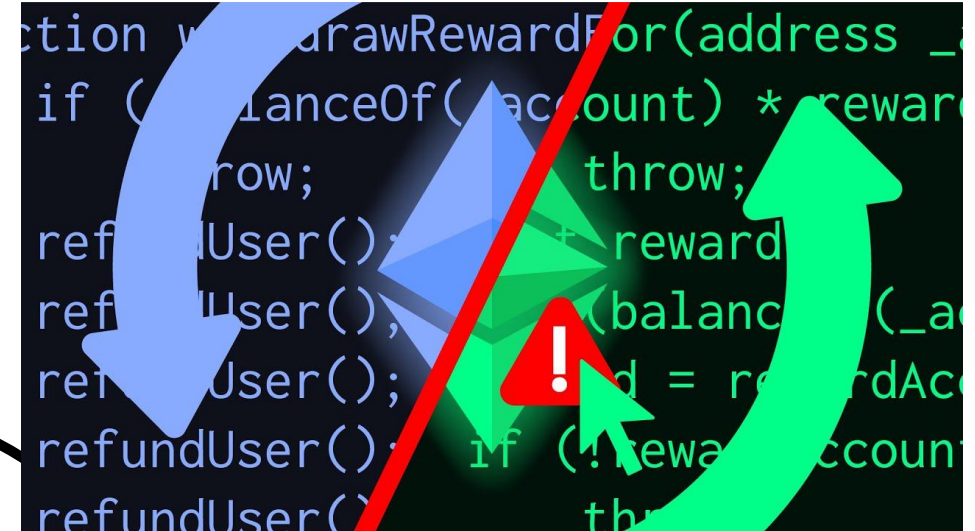
Netzwerk Sicherheit

- Kryptowährungen
- Sicherheitsprotokolle
- Netzwerkangriffe und Web Sicherheit

Software und Systemsicherheit

- Malware
- Software Exploits
- Betriebssystemssicherheit
- Trusted Computing

Lohnt es sich Kryptowährungen anzuschauen?



Kursentwicklung

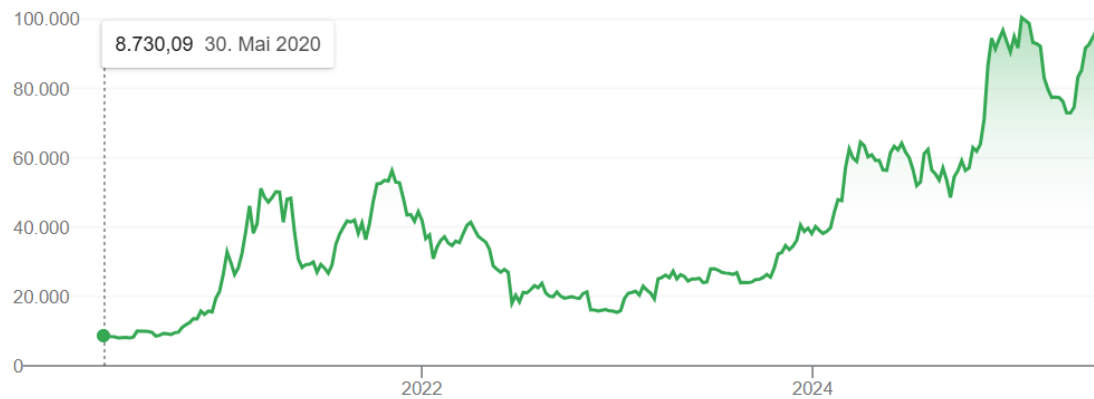
Marktbericht > Bitcoin

96.951,44 EUR

+88.221,35 (1.010,54 %) ↑ in den letzten 5 Jahren

27. Mai, 14:18 UTC · [Haftungsausschluss](#)

1 T. | 5 T. | 1 M. | 6 M. | YTD | 1 J. | 5 J. | Max.



1

BTC ▼

96951,44

EUR ▼

Marktbericht > Ether

2.343,85 EUR

+2.124,81 (970,05 %) ↑ in den letzten 5 Jahren

27. Mai, 14:19 UTC · [Haftungsausschluss](#)

1 T. | 5 T. | 1 M. | 6 M. | YTD | 1 J. | 5 J. | Max.



1

ETH ▼

2343,85

EUR ▼

Kryptowährungen

Credit vs Cash



- Zentralisiert
- Vertrauen in eine Dritte Partei, z.B. Bank, PayPal
- Nicht anonym



- Dezentral
- Bessere Anonymität
- Offline

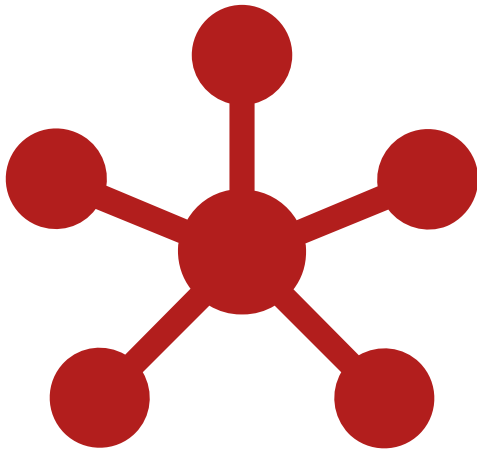
- Dezentral, peer-to-peer Netzwerk
- Keine perfekte Anonymität sondern Pseudonymität
- Im Regelfall funktioniert Bitcoin nicht vollständig offline
 - Ausnahme: Offline Payment Protokolle



Centralization vs Decentralization

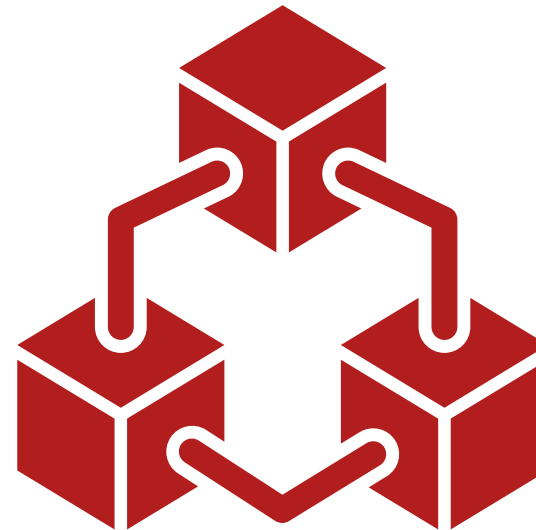
Centralized Systems

- Email Providers (Gmail)
- Social Networking (Facebook, LinkedIn)
- Bitcoin exchanges



Decentralized Systems

- Das Internet
- Email (SMTP)
- Das Bitcoin Netzwerk



Hauptprobleme in der Forschung



Anonymität



Dezentrales System



Das Double-Spending Problem



Prägung (Minting) des digitalen Geldes

- Consensus Protokolle
 - Byzantinische Generäle Problem (L. Lamport, R. Shostak und M. Pease, 1980)
- Ecash
 - David Chaum gründet die Firma DigiCash (1989)
- Tamper-Evident Log
 - Blockchain-basiertes System zum Zeitstempeln von Dokumenten (Haber und Stornetta, 1991)
- Merkle Bäume
 - Hash-Baum entwickelt von Ralph Merkle (1979)
 - Teilen von digitalen Coins (T. Okamoto und K. Ohta, 1991)

Die Eigenschaft von Knappheit (Scarcity) bei Gold in die digitale Welt übertragen?

- Knappheit: Rechenleistung
- Plugin für Email Clients um Spam zu erschweren
- Ein mathematisches Puzzle muss vor jedem Versand einer Email gelöst werden
- Voraussetzungen
 - Lösung des Puzzles ist sehr schwer; Verifizieren der Lösung aber sehr schnell
 - Puzzles müssen voneinander unabhängig sein
 - Der Schweregrad (Difficulty) muss konfigurierbar sein

Hashcash Beispiel

```
From: Someone <test@test.invalid>  
To: Adam Back <adam@cypherspace.org>  
Subject: test hashcash  
Date: Thu, 26 Jun 2003 11:59:59 +0000  
X-Hashcash: 0:030626:adam@cypherspace.org:
```

Puzzle Lösung

blah blah

-Someone

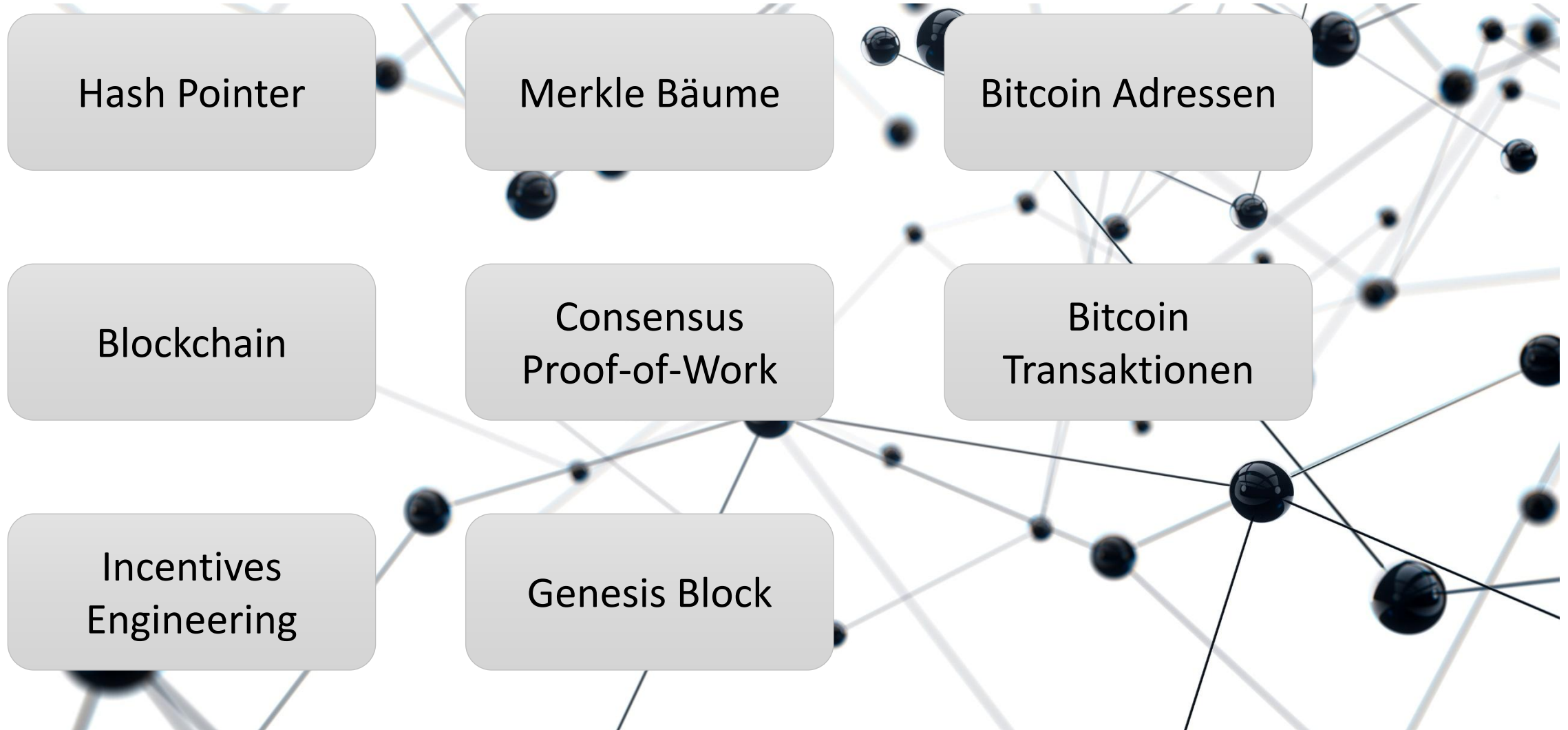
Finde eine teilweise Hash-Kollision wo die ersten 32 Bits 0 sind

<http://www.sha1-online.com/>

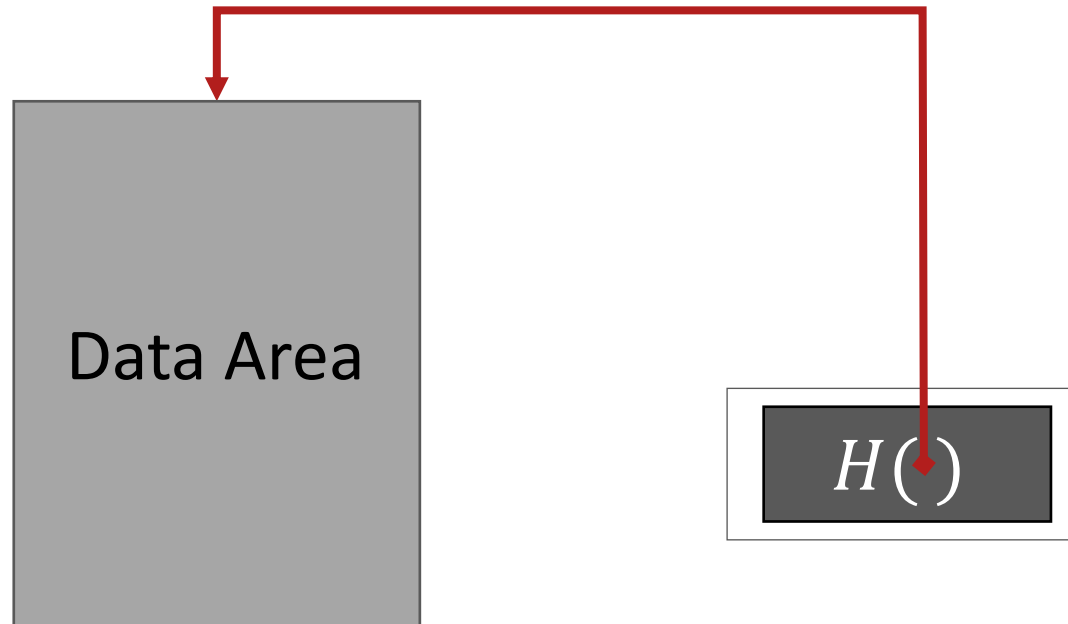
```
echo -n 0:030626:adam@cypherspace.org:6470e06d773e05a8 | sha1  
00000000c70db7389f241b8f441fcf068aead3f0
```

Bitcoin

Bitcoin Big Picture

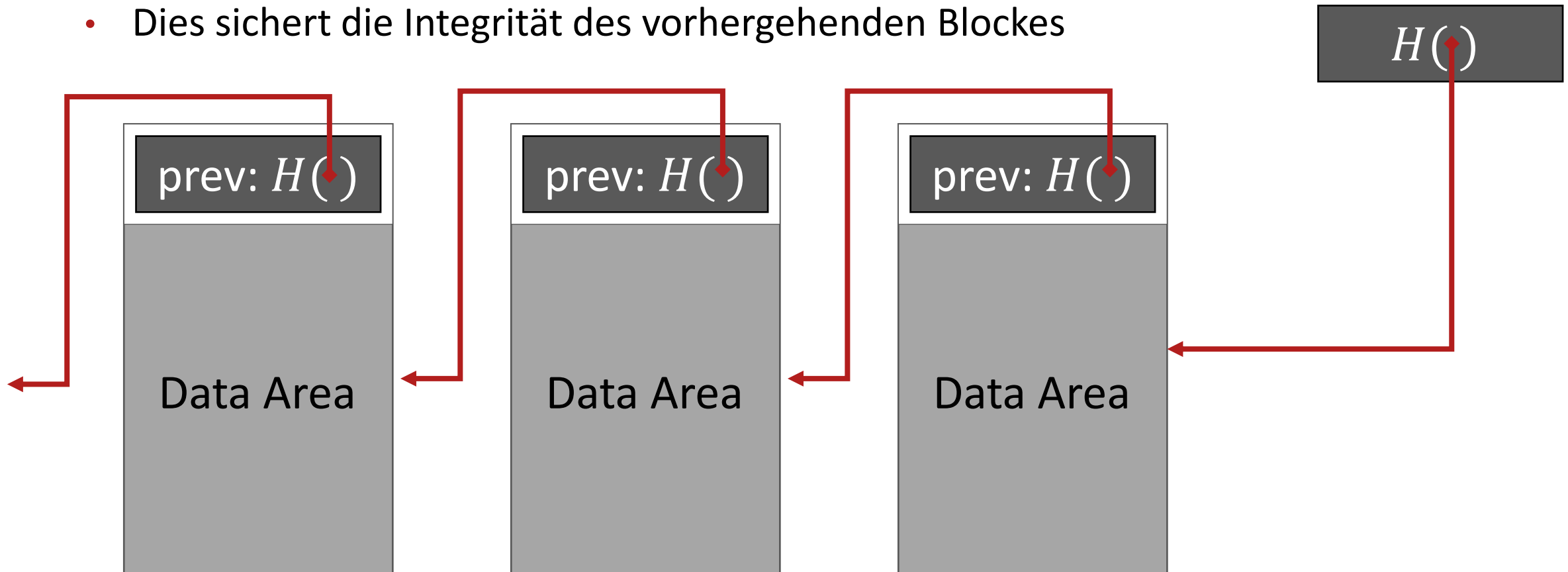


- Was ist ein Pointer?
 - Ein Zeiger auf einen bestimmten Datenbereich
- Was ist ein Hash Pointer?
 - Ein Zeiger, der zusätzlich die Verifikation des Datenbereichs erlaubt



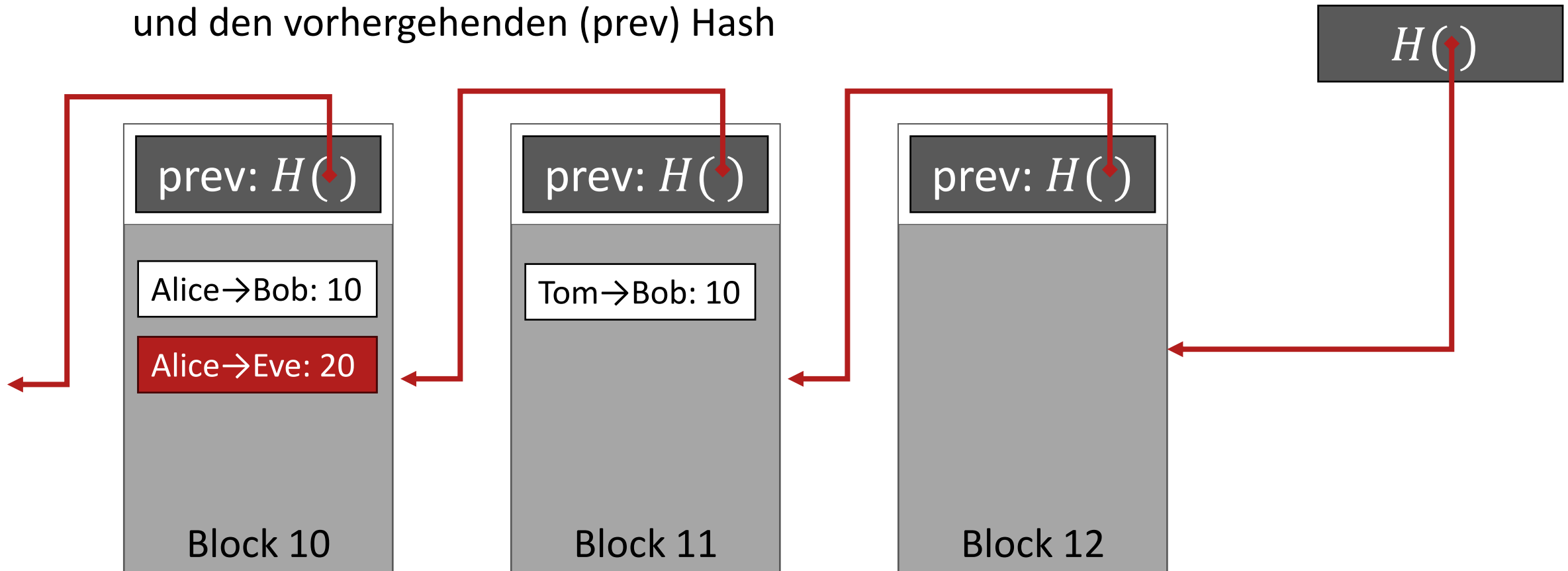
Tamper-Evident Log: Blockchain mit Hash Pointers

- Ähnlich zu Linked Lists, aber der Pointer zum vorhergehenden Block (prev) wird mit einem Hash Pointer ersetzt
- Dies sichert die Integrität des vorhergehenden Blockes



Versuch der Datenänderung in der Blockchain

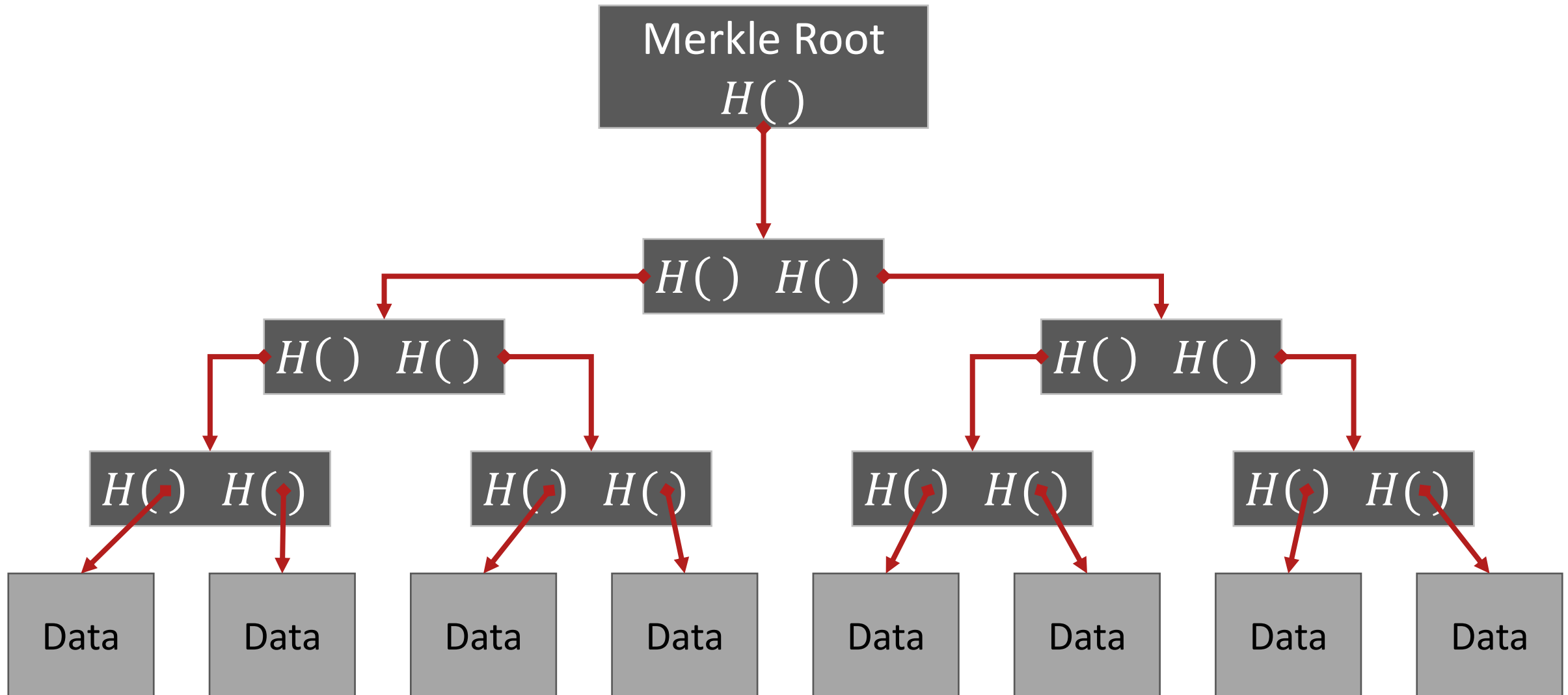
- **Szenario:** Eve verfälscht die Transaktion in Block 10
- **Beachte:** Die Hash Berechnung umfasst alle Daten des Blocks, d.h. Transaktionen und den vorhergehenden (prev) Hash



- Der Angreifer muss alle Hash-Werte der folgenden Blöcke ersetzen
- Solange der Top Hash-Wert sicher gespeichert ist, werden alle Änderungen bemerkt
- Wir können somit eine Blockchain beliebiger Länge bilden, die auf einen Ursprungsblock (Genesis Block) zurückgeht

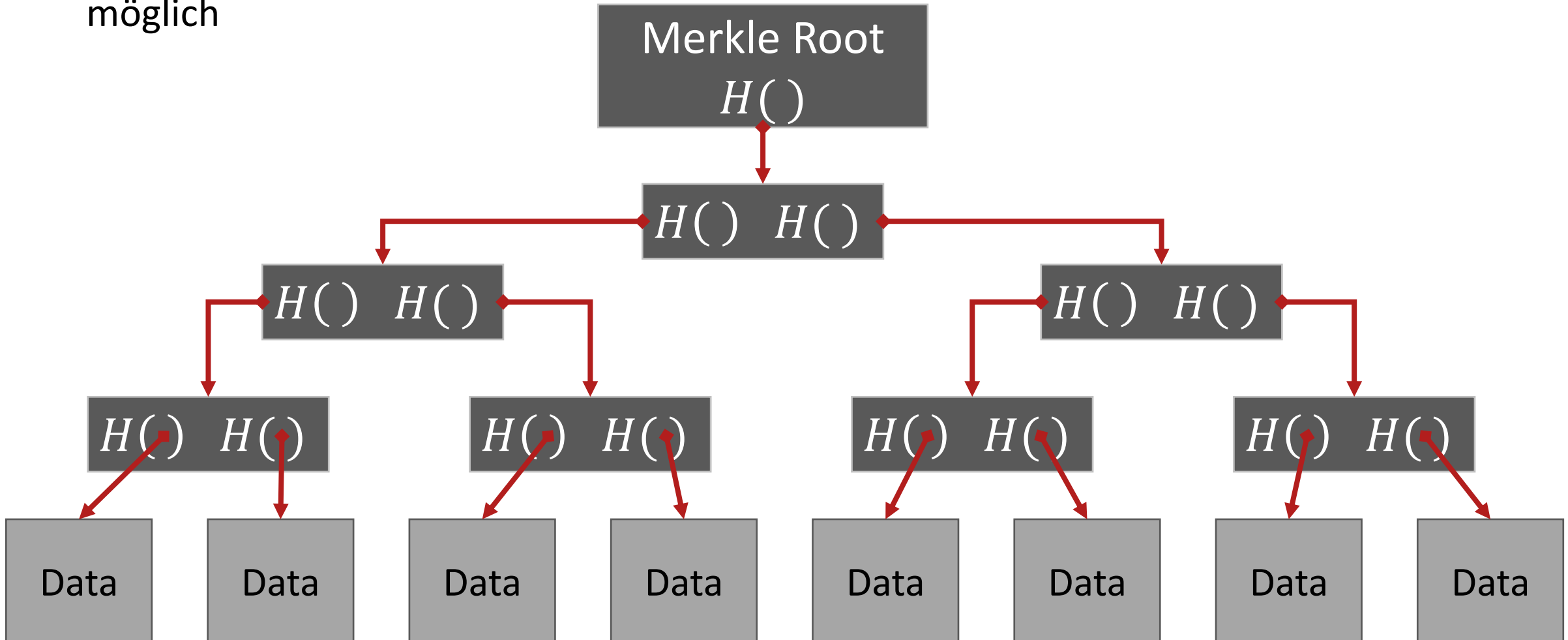
- 1979 erfindet Ralph Merkle den Hash-Baum (hash tree)
 - Binärbaum mit Hash Pointern
- Ursprünglicher Zweck war die Effizienzsteigerung von Signaturverfahren
- Wurzel (Root) des Baumes wird als Merkle Root bezeichnet

Aufbau von Merkle Bäumen



Vorteile von Merkle Bäumen

Im Gegensatz zur vorher gezeigten Blockchain sind Proof of Membership effizient möglich



- Public Keys können als Identitäten genutzt werden
- Warum ist dies möglich?
 - Eine korrekt signierte Nachricht mit k_{pub} kann nur von der Person erstellt worden sein, die im Besitz von k_{pr} ist
- Welche Vorteile ergeben sich daraus?
 - Dezentrales Identity Management: Jeder kann beliebig viele neue Identitäten erzeugen
 - Es muss lediglich ein neues Schlüsselpaar generiert werden

- Bitcoin Adressen werden aus Public Keys abgeleitet
- Eine Bitcoin Adresse kann man sich als IBAN vorstellen
- Da Public Keys sehr lang sein können, wird eine Bitcoin Adresse wie folgt generiert:



1. SHA256
2. RIPEMD160

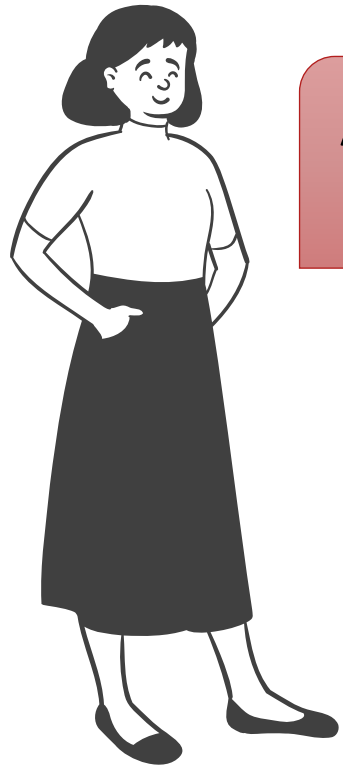
3. Prefix mit 00
4. Base58Check

Wie schafft das Bitcoin Protokoll ein dezentrales System aufzubauen?

Distributed Consensus

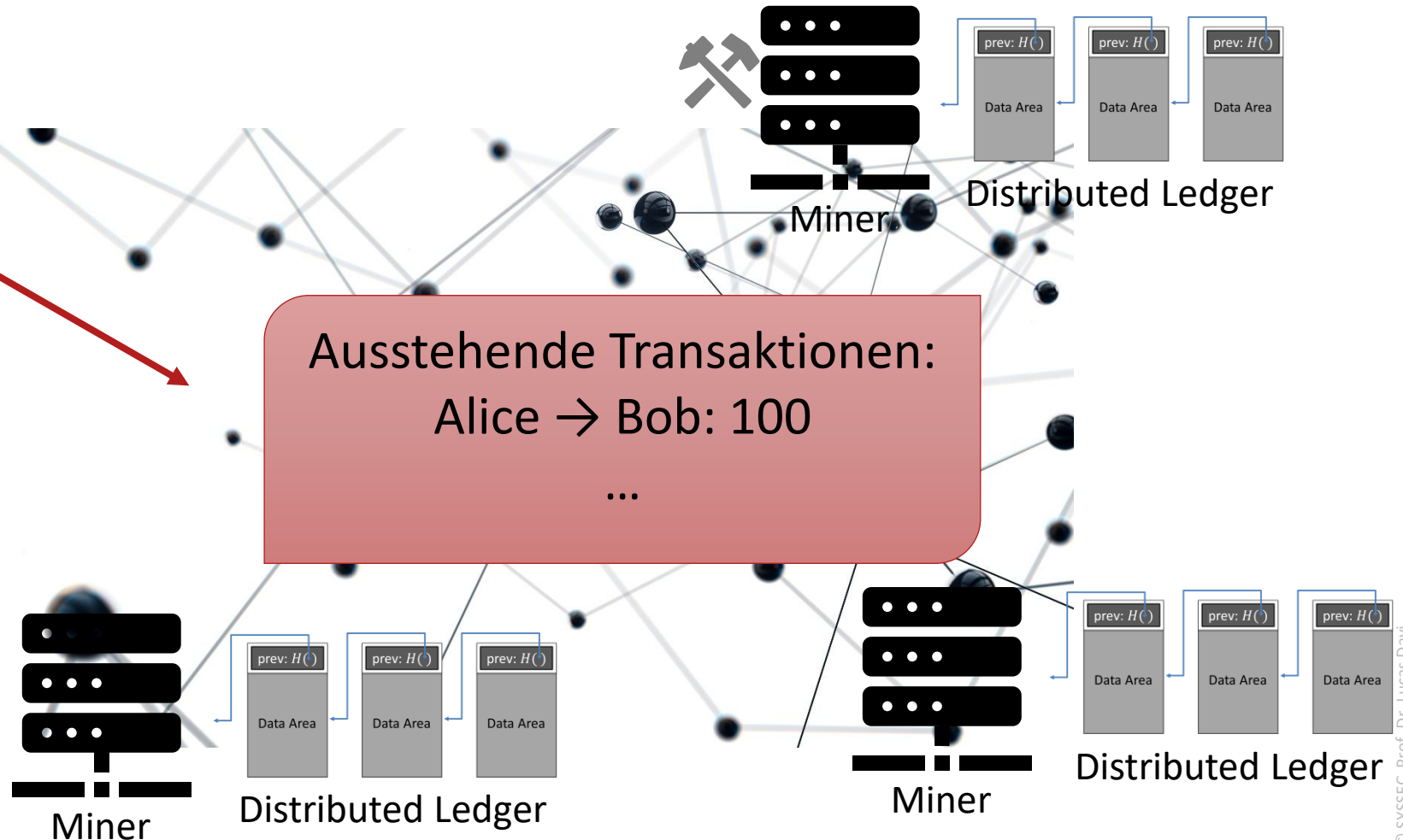
Szenario: Alice schickt 100 Coins an Bob

Alice



Alice → Bob: 100
signed by Alice

Ausstehende Transaktionen:
Alice → Bob: 100
...



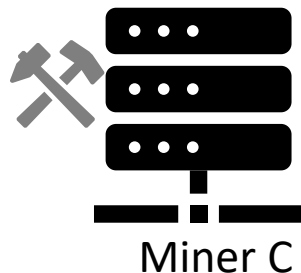
Wir betrachten zuerst folgendes Szenario:

- Alle Knoten haben eine Sequenz von Blöcken (die Blockchain) für die bereits Consensus erreicht wurde
- Zusätzlich verwaltet jeder Knoten einen Pool an ausstehenden Transaktionen
- Für diese Transaktionen muss nun Consensus im Netzwerk erreicht werden

Bitcoin Consensus Algorithmus (Vereinfacht)

1. Neue Transaktionen werden an alle Knoten im Netzwerk per Broadcast gesendet
2. Jeder Knoten sammelt neue Transaktionen in einem Block
3. In jeder Runde wird **ein zufälliger Knoten ausgewählt**, um dem Netzwerk per Broadcast seinen Block mitzuteilen (*hier ist die Vereinfachung*)
4. Die anderen Knoten akzeptieren den Block nur wenn alle darin enthaltenen Transaktionen gültig sind (Coins noch nicht ausgegeben, Signaturen gültig)
5. Knoten zeigen ihre Akzeptanz des Blockes indem sie den Hash des Blockes im nächsten Knoten, den sie erzeugen aufnehmen

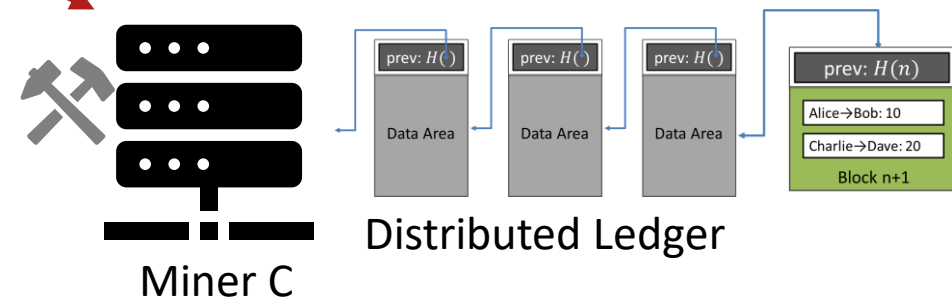
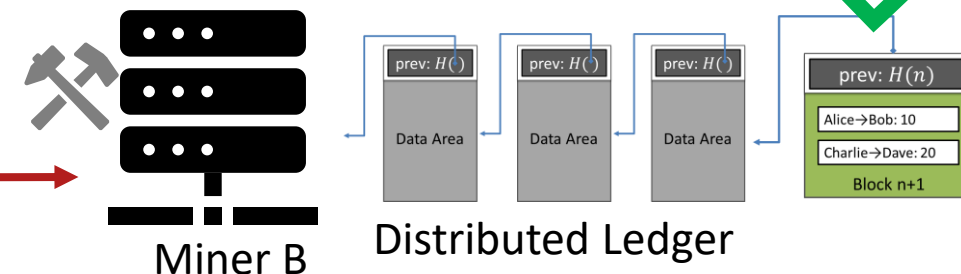
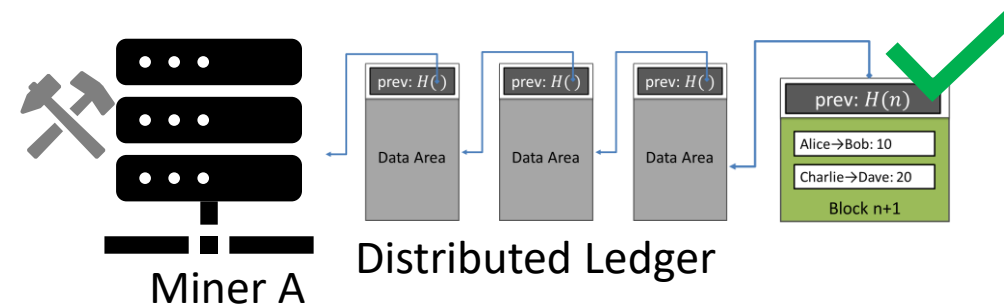
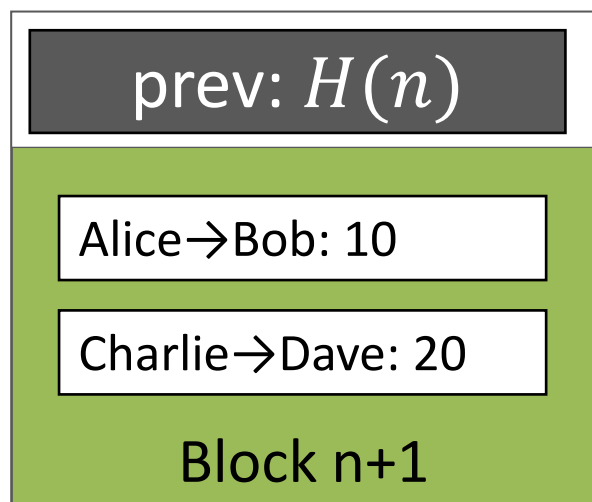
Beispiel



Ausstehende
Transaktionen:
Alice → Bob: 100
Charlie → Dave: 20

Alice → Bob: 100
signed by Alice

Charlie → Dave: 20
signed by Charlie

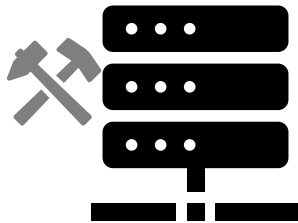
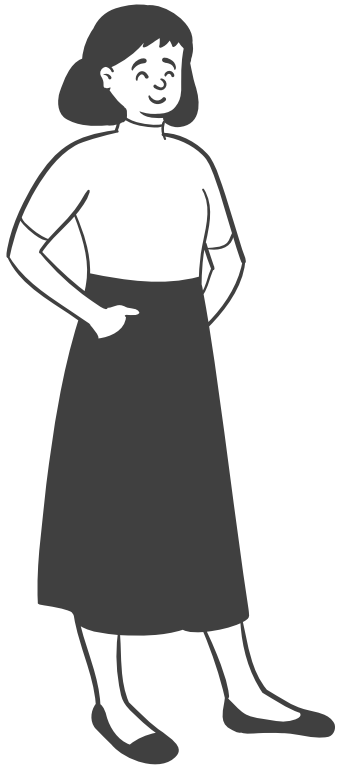


Wie sicher ist der vereinfachte Bitcoin Consensus Algorithmus?

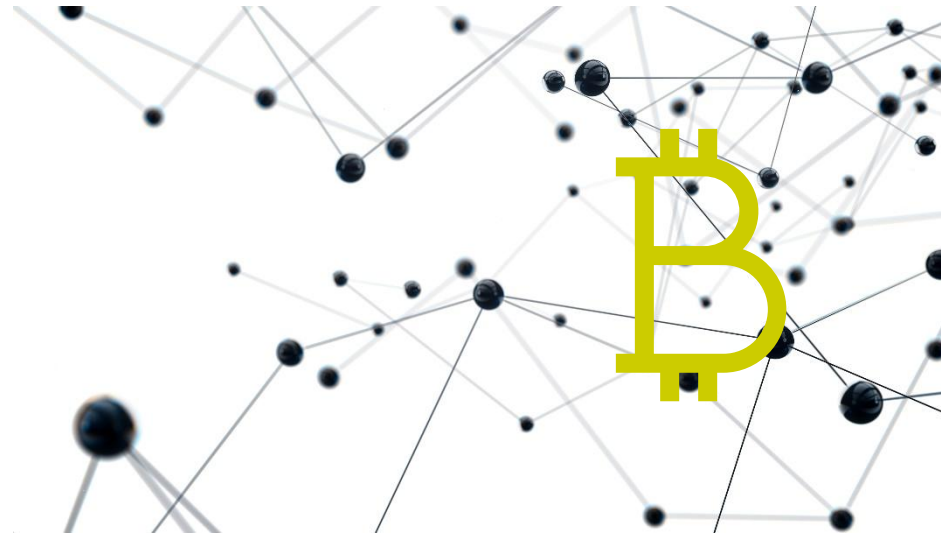
Double-Spend Angriff (1)

Szenario:

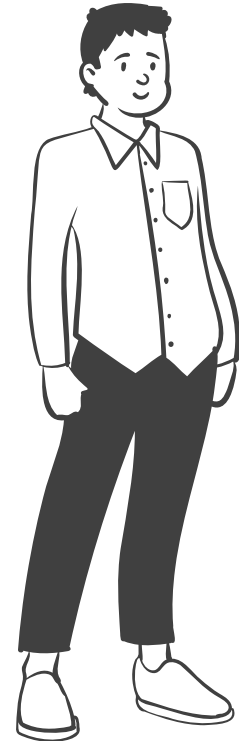
Alice



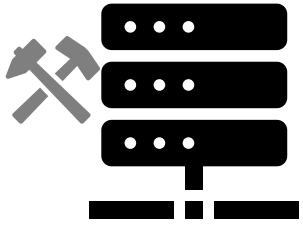
Miner



Bob



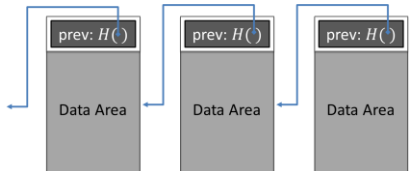
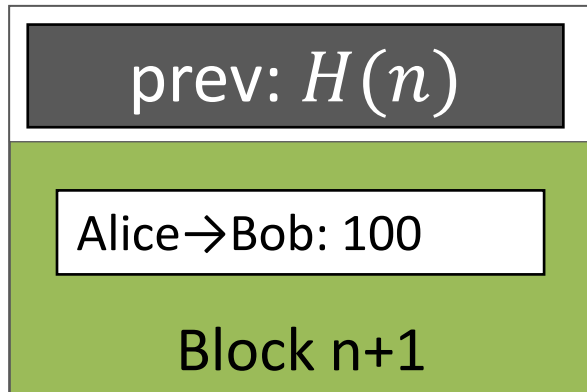
Online Shop



Miner (Honest)

Double-Spend Angriff (2)

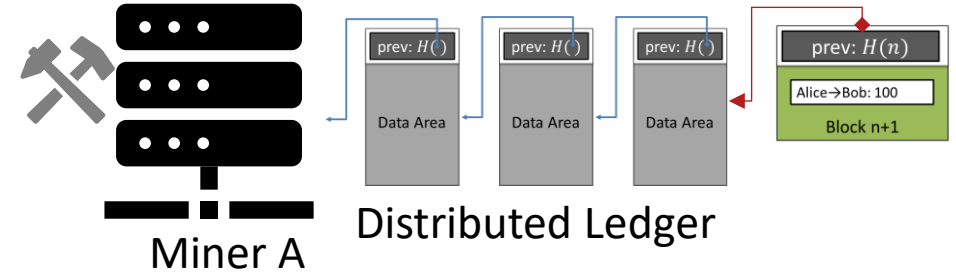
Ausstehende
Transaktionen:
Alice → Bob: 100



Distributed Ledger

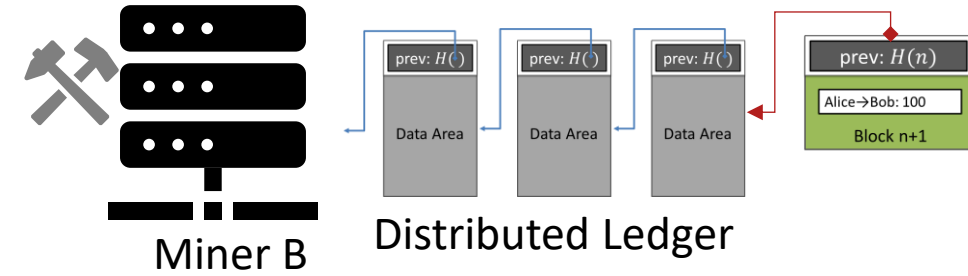
Alice → Bob: 100
signed by Alice

✓ Valid signature and
Alice owns 100 Bitcoin



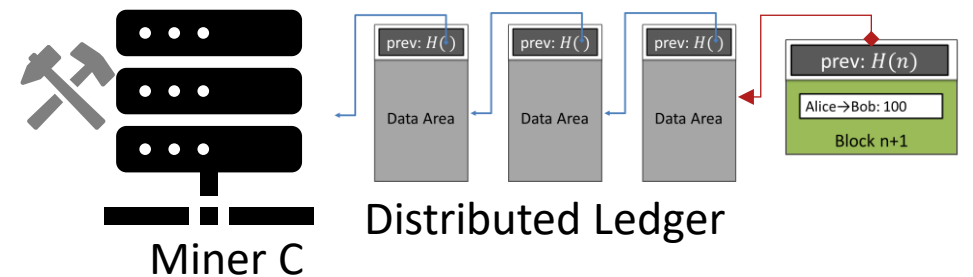
Miner A

Distributed Ledger



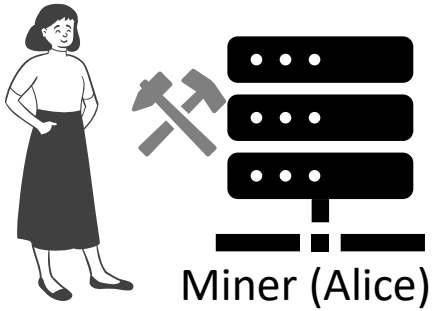
Miner B

Distributed Ledger



Miner C

Distributed Ledger



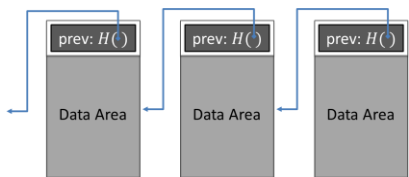
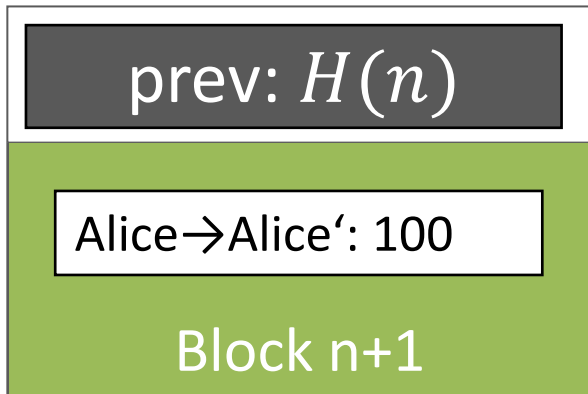
Double-Spend Angriff (3)

Ausstehende
Transaktionen:
Alice → Alice': 100

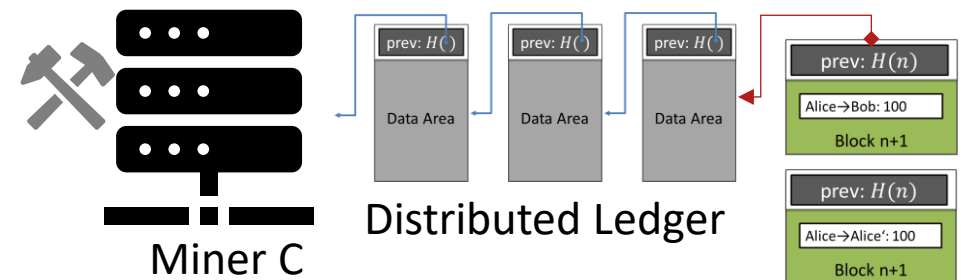
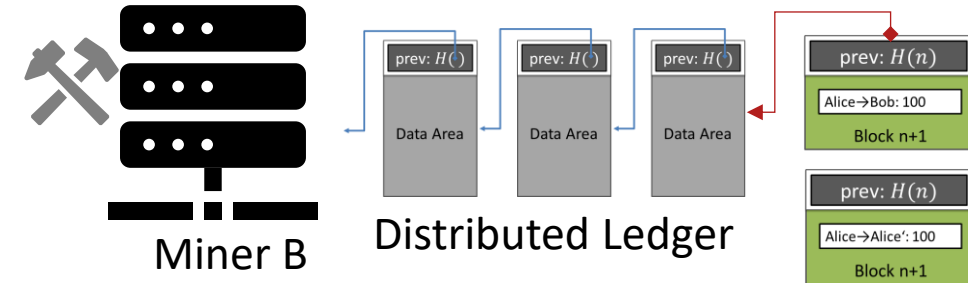
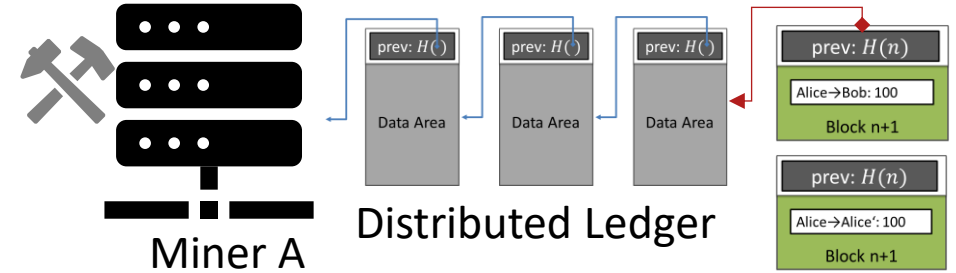
Alice → Alice': 100
signed by Alice

Double-Spend!

✓ Valid signature and
Alice owns 100 Bitcoin



Distributed Ledger



Double-Spend Angriff (4)

Welcher Block wird langfristig in die Blockchain aufgenommen?

- ...der Block mit Alice → Bob: 100 oder der mit Alice → Alice': 100
- Die Antwort darauf ist schwer zu bestimmen

Aber: Longest Chain Wins

- Im Angriffszenario existieren jetzt 2 Branches, die erstmal von allen Minern verwaltet werden
- In der nächsten Runde entscheidet der Knoten auf welchen Branch er aufbauen will
- Im allgemeinen Fall wird auf dem Branch aufgebaut, den der Knoten als erstes gesehen hat
- Langfristig wird einer der Branches länger als der andere sein
- Der kürzere Branch wird somit obsolet

Double-Spend Angriff (5)

Was ist wenn Bob noch nicht mal auf die erste Bestätigung wartet

- Hierbei würde man von einer Zero-Confirmation Transaction sprechen
- Alice hätte in diesem Fall die Möglichkeit sofort eine Double-Spend Transaktion zu senden
- Der Miner wird entweder die Zahlung an Bob oder die Double-Spend Transaktion in seinem Block aufnehmen
- Der Angriff hätte somit eine höhere Erfolgschance

Was ist wenn Bob einige Bestätigungen abwartet?

- Die Erfolgschancen für Alice sinken erheblich
- Je mehr Bestätigungen gesehen werden, um so höher die Wahrscheinlichkeit, dass die Transaktion langfristig in der Blockchain sein wird
- Faustregel: Nach 6 Bestätigungen ist die Chance für einen Double-Spend gleich Null

Bitcoin Incentives Engineering



BLOCK REWARD



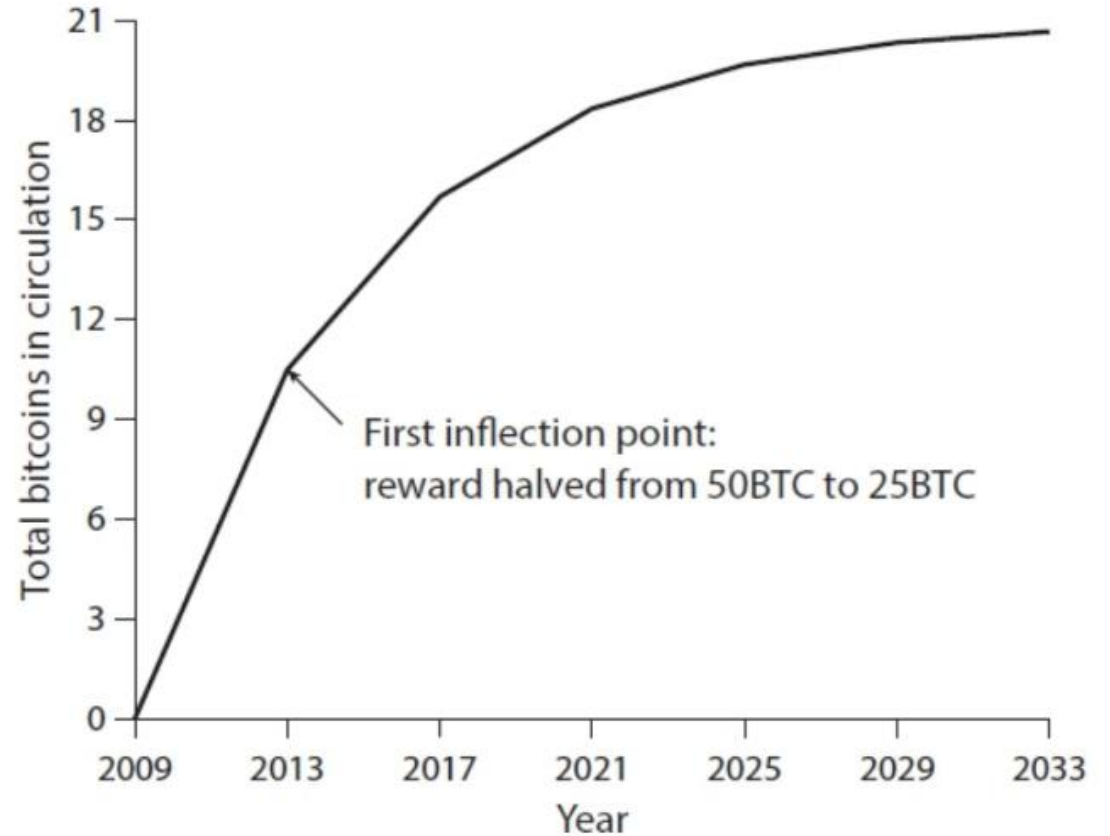
TRANSACTION FEE

- Bis jetzt haben wir angenommen, dass wir zufällig einen Knoten auswählen, um den nächsten Block zu erzeugen
- Implizit haben wir auch angenommen, dass die meisten (>50%) der Knoten gutartig sind (honest nodes)
- Wie können wir die Knoten motivieren sich korrekt zu verhalten?
 - Bitcoin wählt den Ansatz einer Belohnung (in Form von Bitcoin) für korrektes Verhalten

- Jeder Block enthält eine spezielle Coin-Creation Transaktion
- In Bitcoin die sogenannte coinbase Transaktion
- Diese Bitcoin gehen an eine beliebig wählbare Bitcoin-Adresse
 - Grundsätzlich an eine Adresse des Miners des Blockes
- Block Reward verkleinert sich im Laufe der Zeit
- Alle 210.000 Blöcke wird der Block Reward halbiert
 - In den ersten Jahren war der Block Reward 50 Bitcoin
 - 2012: 25 Bitcoin
 - 2016: 12,5 Bitcoin
 - 2020: 6,25 Bitcoin
 - 2024: 3,125 Bitcoin (*im April*)

Block Reward über die Zeit

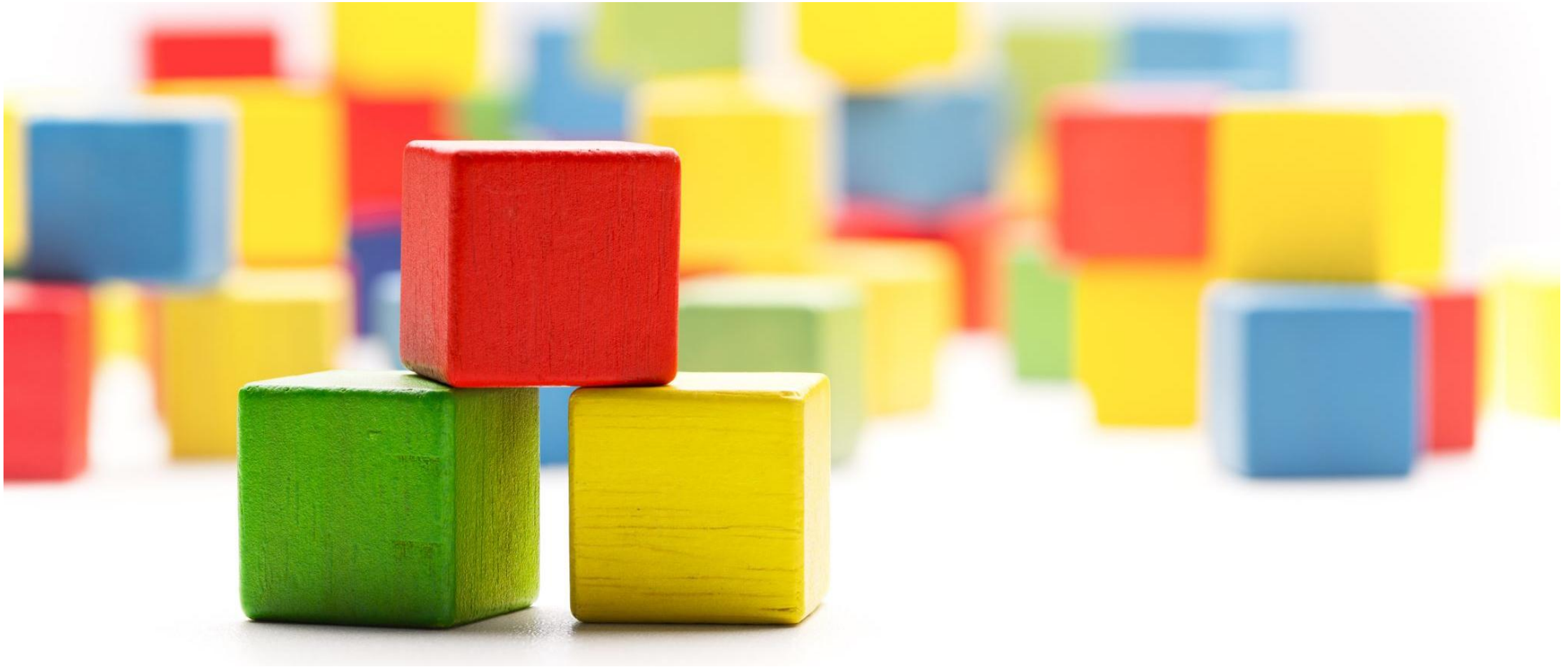
- Der Block Reward wird immer kleiner
- Im Jahre 2140 wird der Block Reward auf Null gehen und keine Bitcoins mehr generiert
- Es gibt ein finales Maximum von 21 Millionen Bitcoin, die im Umlauf sein werden



- Dieser Mechanismus sorgt dafür, dass auch nach dem Jahr 2140 Knoten motiviert werden sich korrekt zu verhalten
- Transaction Fees werden jeder Transaktion angehängt
- Dafür wird der Transaction Output kleiner als der Input gewählt
- Die Differenz wird dem Block Miner gutgeschrieben
- Im Allgemeinen wird erwartet, dass die Transaction Fees im Laufe der Zeit steigen werden

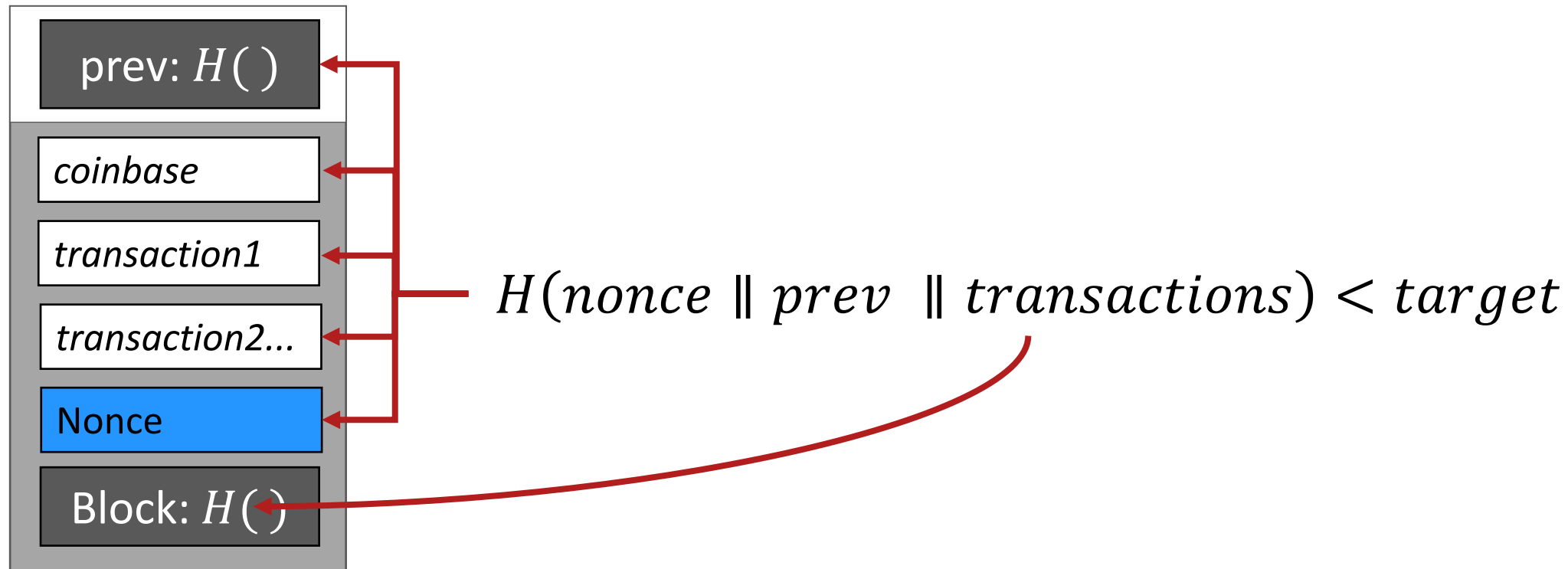
Proof-of-Work

Wir lassen jetzt unsere Vereinfachung bzgl. der Wahl eines zufälligen Knotens zur Generierung des nächsten Blocks entfallen



Hash Puzzle in Proof-of-Work

- Bitcoin nutzt einen Wettbewerb zwischen Knoten auf Basis der begrenzten Verfügbarkeit von Rechenkapazität (Computing Power)
- Bitcoin nutzt dafür Hash Puzzles (s. Folien zu Hashcash)
- Um einen Block zu generieren muss eine Zahl gefunden werden, die sogenannte Nonce



The Genesis Block

00000000	01 00 00 00 00 00 00 00	00 00 00 00 00 00 00 00	
00000010	00 00 00 00 00 00 00 00	00 00 00 00 00 00 00 00	
00000020	00 00 00 00 3B A3 ED FD	7A 7B 12 B2 7A C7 2C 3E	;fíýz{.²zÇ,>
00000030	67 76 8F 61 7F C8 1B C3	88 8A 51 32 3A 9F B8 AA	gv.a.È.Ã^ŠQ2:Ÿ_a
00000040	4B 1E 5E 4A 29 AB 5F 49	FF FF 00 1D 1D AC 2B 7C	K.^J)«_IŸŸ...¬+
00000050	01 01 00 00 00 01 00 00	00 00 00 00 00 00 00 00	
00000060	00 00 00 00 00 00 00 00	00 00 00 00 00 00 00 00	
00000070	00 00 00 00 00 00 FF FF	FF FF 4D 04 FF FF 00 1D	ŸŸŸŸM.ŸŸ..
00000080	01 04 45 54 68 65 20 54	69 6D 65 73 20 30 33 2F	..EThe Times 03/
00000090	4A 61 6E 2F 32 30 30 39	20 43 68 61 6E 63 65 6C	Jan/2009 Chancel
000000A0	6C 6F 72 20 6F 6E 20 62	72 69 6E 6B 20 6F 66 20	lor on brink of
000000B0	73 65 63 6F 6E 64 20 62	61 69 6C 6F 75 74 20 66	second bailout f
000000C0	6F 72 20 62 61 6E 6B 73	FF FF FF FF 01 00 F2 05	or banksŸŸŸŸ..ò.
000000D0	2A 01 00 00 00 43 41 04	67 8A FD B0 FE 55 48 27	*....CA.gŠŸ°pUH'
000000E0	19 67 F1 A6 71 30 B7 10	5C D6 A8 28 E0 39 09 A6	.gñ q0·.\Ö"(à9.
000000F0	79 62 E0 EA 1F 61 DE B6	49 F6 BC 3F 4C EF 38 C4	ybâê.aP¶Iö¼?Lî8Ä
00000100	F3 55 04 E5 1E C1 12 DE	5C 38 4D F7 BA 0B 8D 57	óU.å.Á.Þ\8M÷º..W
00000110	8A 4C 70 2B 6B F1 1D 5F	AC 00 00 00 00	ŠLp+kñ._¬....

<https://twitter.com/hodlwithLedn/status/1478068591966707717>

Die ersten Bitcoin Blöcke

- Bis Block Nr. 170 gab es nur Blöcke mit der coinbase Transaktion
- Im Block Nr. 170 hat Satoshi Nakamoto 10 Bitcoin an Hal Finney gesendet
- Dies ist die erste (nicht-coinbase) Transaktion in Bitcoin

TRANSACTION RECEIPT

BITCOIN

TRANSACTION IDENTIFIER:

[f4184fc596403b9d638783cf57adfe4c75c605f6356fbc91338530e9831e9e16](#)

TRANSACTION TIMESTAMP:

[2009-01-12 03:30 \(UTC\)](#)

CONFIRMED TRANSACTION:

Included in block: [#170](#) on the [Bitcoin](#) blockchain

SENDERS (INPUTS):

#	SENDER	VALUE (BTC)	VALUE (USD)
0	12cbQLTFMXRnSzktFkuoG3eHoMeFtpTu3S	50.00000000	0.50
TOTAL: 50.00000000 BTC 0.50 USD			

RECIPIENTS (OUTPUTS):

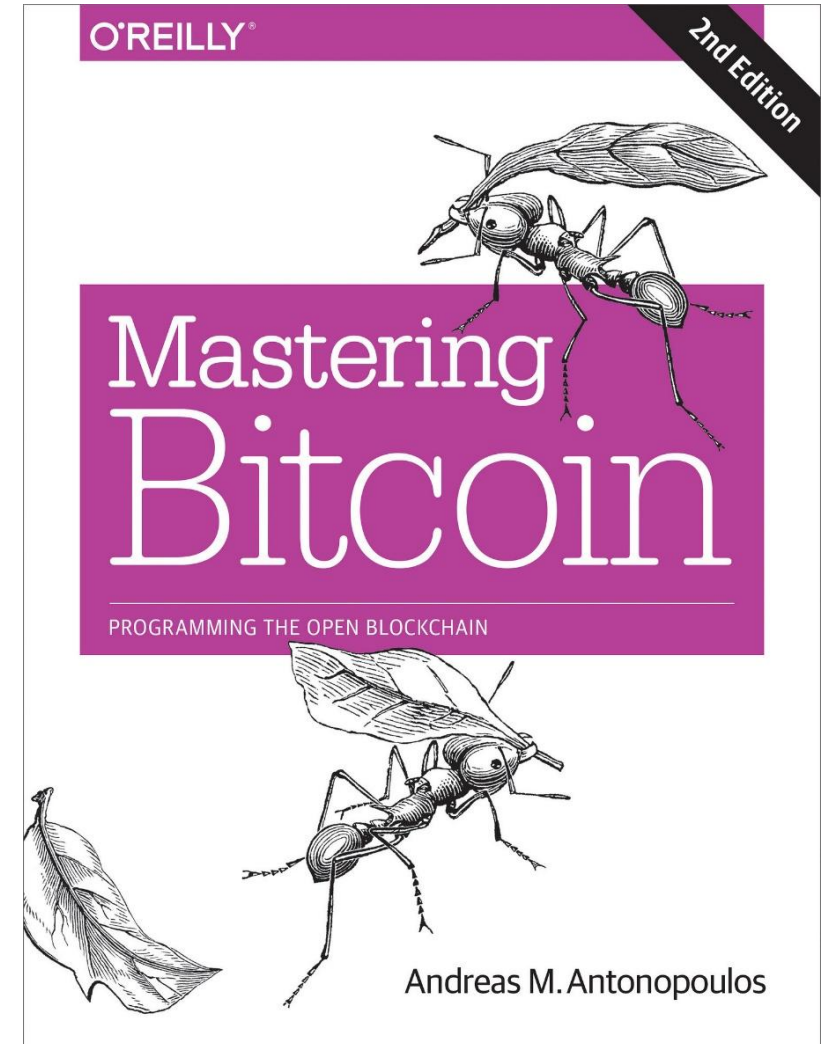
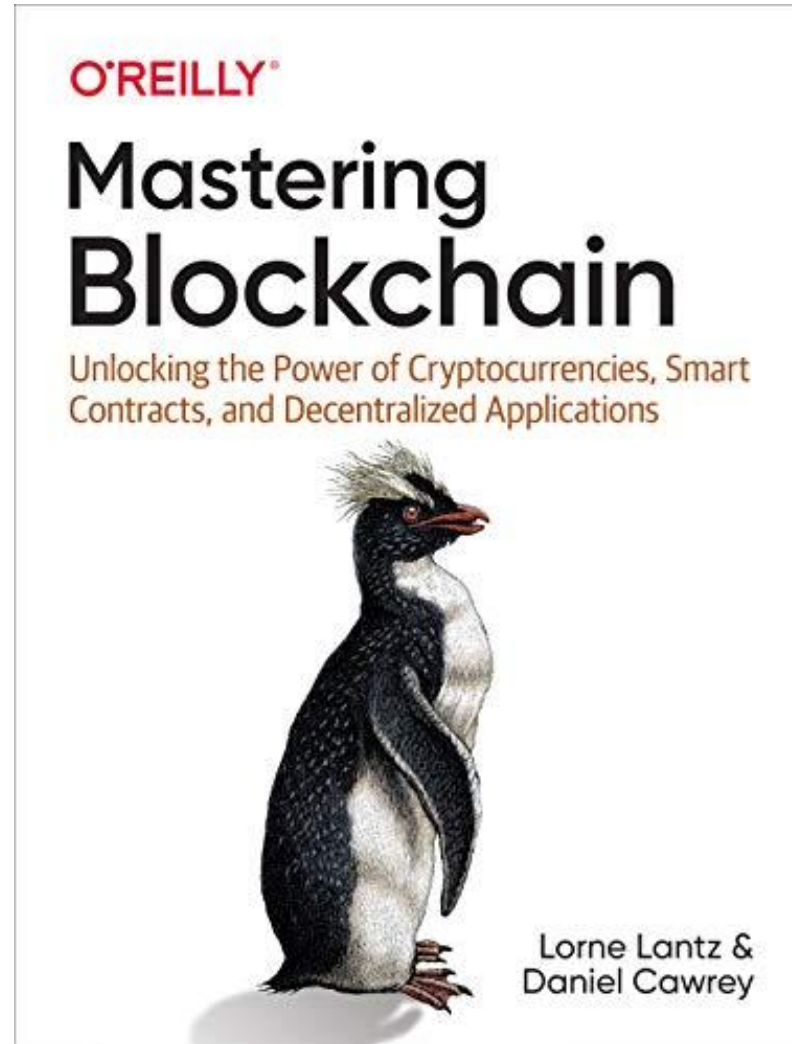
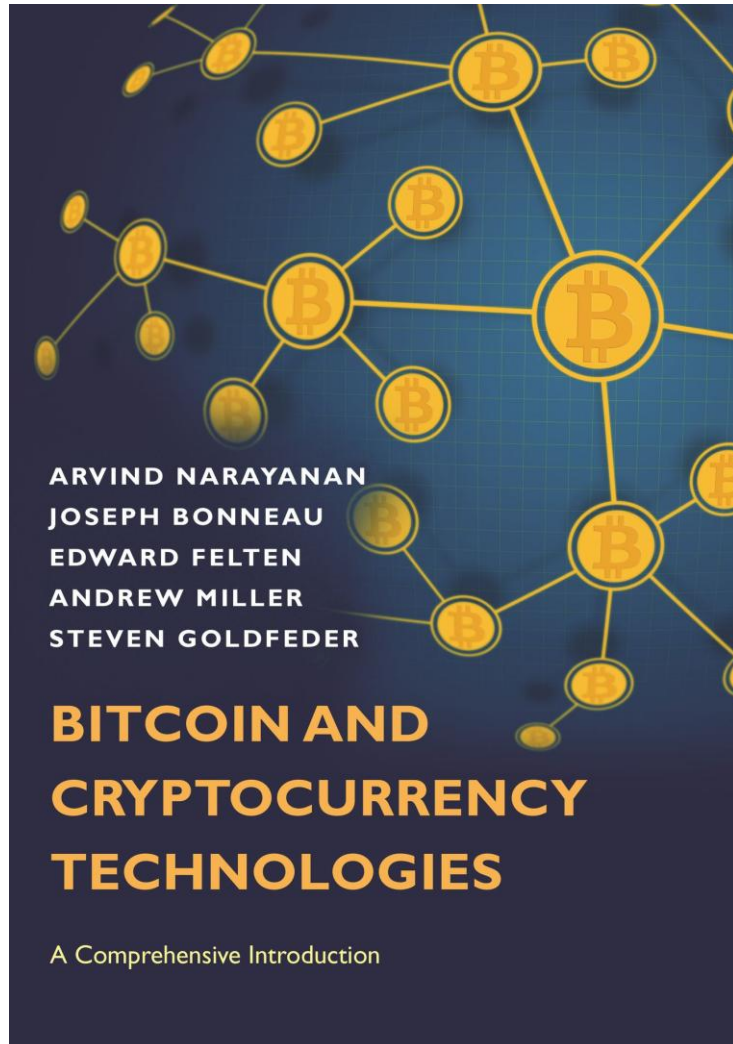
#	RECIPIENT	VALUE (BTC)	VALUE (USD)
0	1Q2TWHE3GMdB6BZKafqwxXtWAWgFt5Jvm3	10.00000000	0.10
1	12cbQLTFMXRnSzktFkuoG3eHoMeFtpTu3S	40.00000000	0.40
/	* * * MINER FEE * * *	**	**
→ TOTAL: 50.00000000 BTC 0.50 USD			

Bitcoin Pizza Day

laszlo Full Member 👤👤👤 Activity: 199 Merit: 149 👤📁	 Re: Pizza for bitcoins? May 21, 2010, 09:33:45 PM I just think it would be interesting if I could say that I paid for a pizza in bitcoins 😊 BC: 157fRrqAKrDyGHR1Bx3yDxeMv8Rh45aUet	#10
laszlo Full Member 👤👤👤 Activity: 199 Merit: 149 👤📁	 Re: Pizza for bitcoins? May 22, 2010, 07:17:26 PM I just want to report that I successfully traded 10,000 bitcoins for pizza. Pictures: http://heliacal.net/~solar/bitcoin/pizza/ Thanks jercos! BC: 157fRrqAKrDyGHR1Bx3yDxeMv8Rh45aUet	#11
sirius Bitcoiner Sr. Member 👤👤👤👤	 Re: Pizza for bitcoins? May 22, 2010, 10:10:25 PM Congratulations laszlo, a great milestone reached 🎉	#12

Wie finden Miner heraus, ob Bitcoin bereits ausgegeben wurden?

- Unspent Transaction Output (UTXO)
- Eine Transaktion besteht aus Inputs und Outputs
 - Ein Input beinhaltet eine Bitcoin Adresse und eine *Unspent Transaction*, welche diese Bitcoin Adresse erhalten hat
 - Ein Output definiert eine Bitcoin Adresse und die Menge an Bitcoin, die diese Adresse erhält
- Die Differenz zwischen Input und Output ist die Transaction Fee
- Jeder Input enthält eine Signatur



Vorlesung Cybersicherheit, Sommersemester 2025

Vielen Dank für Ihre Aufmerksamkeit

Prof. Dr.-Ing. Lucas Vincenzo Davi
Fakultät für Informatik
Arbeitsgruppe Systemsicherheit
Universität Duisburg-Essen

© SYSSEC, Prof. Dr. Lucas Davi